

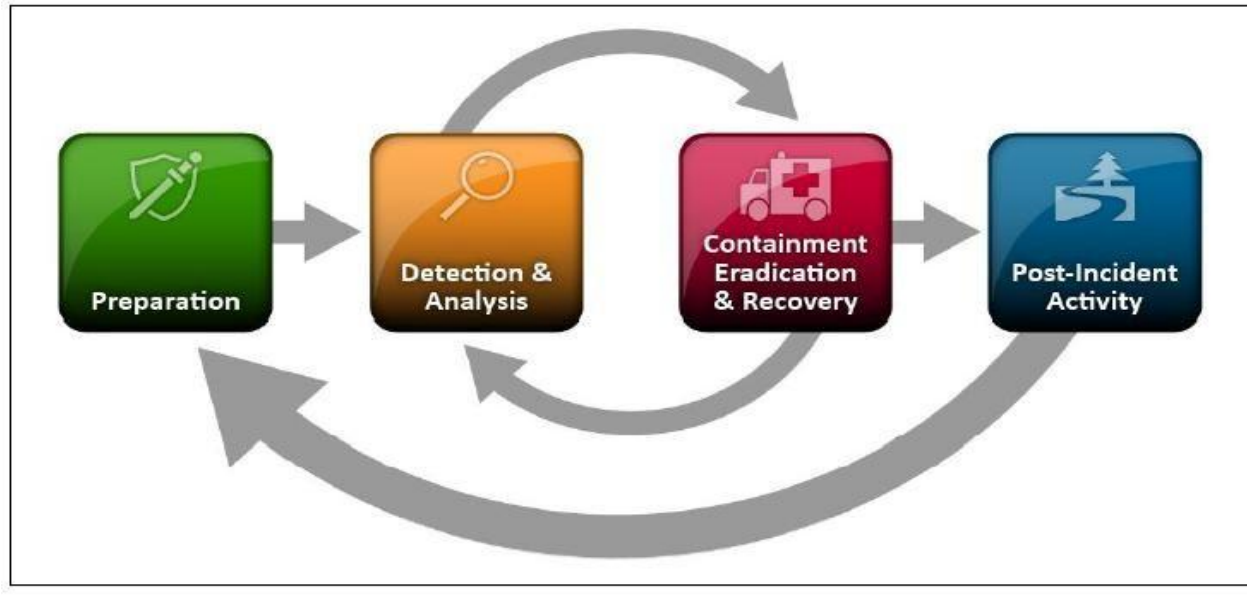
Incident Response Guide



Incident Response Plan Overview :

This plan serves as a universal blueprint, designed to be adaptable for any organization across sectors such as finance, retail, technology, manufacturing, or education. It focuses on protecting sensitive data—ranging from customer information and intellectual property to operational datasets—and ensures alignment with a mix of global and local regulatory frameworks. The plan's flexibility allows it to be customized based on the organization's size, industry, and jurisdictional requirements, providing a robust foundation for incident management.

Security Incident Handling Guide, NIST SP 800-61 Rev. 2)



1.1 Regulatory Framework

- **GDPR (EU Regulation):** Mandates that organizations handling personal data of EU citizens notify data protection authorities within 72 hours of a breach and inform affected individuals without undue delay. Non-compliance can result in fines up to 4% of annual global turnover or €20 million, whichever is higher, emphasizing the need for rapid response and documentation.
- **HIPAA/HITECH (U.S.):** Requires organizations handling protected health information to encrypt data, develop formalized incident response plans, implement multi-factor authentication (MFA), and notify affected individuals within 60 days, with enforcement by the Office for Civil Rights (OCR). This applies only if the organization deals with health-related data.
- **DORA (EU Financial Services):** Obliges financial entities to report incidents to regulators within 24 hours, conduct resilience testing every six months, and undergo regular compliance audits, with penalties including fines and operational restrictions for breaches. Relevance is limited to financial sector organizations.

- **Local Data Protection Laws:** Vary by jurisdiction but typically mandate timely reporting to national cybersecurity authorities (e.g., within 24-72 hours depending on the region), implementation of robust data protection measures, and annual compliance reviews, with fines or sanctions for non-adherence.
- **Industry Standards:** NIST SP 800-61 provides a structured methodology for incident handling, detailing phases and best practices, while ISO/IEC 27001/27035 offer comprehensive frameworks for information security management and incident response, serving as benchmarks for organizational preparedness.

2

Detailed Incident Response Phases

Each phase is elaborated with granular steps, specific tools, compliance considerations, practical examples, and extensive explanatory notes to ensure thorough understanding and effective execution.

2.1

Preparation

- **Team Training and Awareness:**

- Conduct monthly training sessions, each lasting 4 hours, covering GDPR reporting timelines (72 hours), HIPAA encryption standards (if applicable), DORA resilience testing (if applicable), and local data protection law requirements. Sessions include interactive workshops with real-world case studies, role-playing exercises, and QA segments to reinforce learning.
- Simulate a diverse range of scenarios, such as ransomware encryption of customer databases, sophisticated phishing campaigns targeting multiple employees, and insider data exfiltration attempts using stolen credentials, to build practical response skills and identify training gaps.

- Enroll key personnel in advanced certification courses like Certified Information Systems Security Professional (CISSP), Certified Incident Handler (GCIH), or vendor-specific training (e.g., Splunk Fundamentals) to enhance technical and strategic expertise.
- Distribute a comprehensive 100-page training manual with detailed procedures, quizzes, and reference materials, updated quarterly to reflect emerging threats and regulatory changes.
- Establish a training evaluation process, including post-session assessments and feedback forms, to measure effectiveness and adjust content accordingly.

3• Tools and Infrastructure:

- Deploy SIEM (Splunk Enterprise Security) with custom correlation rules designed to detect breaches across various data types (e.g., financial transactions, customer records, proprietary designs), configured with real-time dashboards and automated alert thresholds.
- Use EDR (CrowdStrike Falcon) for real-time threat hunting, endpoint isolation, automated response capabilities, and detailed incident reporting, with integration into existing security workflows.
- Implement Data Loss Prevention (DLP) tools (e.g., Symantec DLP) to monitor and block unauthorized data transfers, with customizable policies for different departments (e.g., HR, finance) and regular policy reviews.
- Maintain offline encrypted backups following a 3-2-1 strategy (three copies, two different media types—e.g., HDD and tape, one offsite location) to ensure data recoverability, with encryption using AES-256 and regular integrity checks.
- Install network monitoring tools (e.g., Wireshark, SolarWinds) for baseline traffic analysis,

anomaly detection, and forensic readiness, with daily log exports for long-term storage.

- Set up a dedicated incident response lab with virtualized environments to simulate attacks and test tools without impacting production systems.

- **Communication Plan:**

Establish a 24/7 incident response center with a dedicated phone line (+1-800-5551234), encrypted email (ir@organization.com), and a secure web portal for incident reporting, staffed by trained personnel.

- Maintain an up-to-date contact list including GDPR Data Protection Officers, HIPAA OCR (if applicable), DORA regulators (if applicable), local cybersecurity authorities, and backup contacts, with quarterly verification to ensure accuracy.
- Develop a public relations protocol with pre-drafted press releases, a crisis communication team comprising PR specialists and legal advisors, and a social media response strategy to manage stakeholder inquiries during high-profile incidents.
- Set up a secure messaging platform (e.g., Slack with end-to-end encryption) for internal team coordination, with channels for different phases (e.g., containment, recovery) and access logs for accountability.
- Create an escalation matrix outlining communication paths for different severity levels, ensuring rapid dissemination of critical updates.

4• Policy Development:

- Create a 50-page compliance manual detailing encryption protocols (e.g., AES-256 for data at rest, TLS 1.3 for data in transit), MFA implementation using tools like Duo or Okta, incident logging procedures with standardized templates, and legal reporting requirements with sample forms.
- Develop a risk assessment matrix with weighted scores (e.g., ransomware: 9/10 due to financial loss and reputational damage, phishing: 7/10 due to frequency) to prioritize threats, updated semi-annually based on threat intelligence.
- Establish a vendor management policy requiring third-party providers (e.g., AWS, Microsoft Azure) to comply with the organization's security standards, including annual third-party audits, signed SLAs, and incident response clauses. – Draft a

–

business continuity plan (BCP) integrated with the IRP, detailing alternate work sites, critical process prioritization, and recovery time objectives (RTOs), with annual testing to ensure alignment.

- Implement a policy review committee to meet monthly, incorporating feedback from incident responses and regulatory changes.
- **Compliance Step:** Train all staff on NIST SP 800-61 evidence preservation techniques, including detailed chain of custody documentation with hands-on exercises using forensic tools (e.g., FTK Imager), video tutorials, and mock legal proceedings to simulate real-world scenarios.

2.2

Identification

- **Incident Detection:**

- Leverage SIEM to identify anomalies such as 1000 login attempts within 5 minutes, unusual data outflows exceeding 1GB, or system crashes with error logs, with automated alerts sent to the Security Operations Center (SOC) via email, SMS, and dashboard notifications.
- Deploy IDS/IPS (Snort, Suricata) to detect known malware signatures (e.g., Ryuk ransomware, Emotet) and unknown threats through behavioral analysis, with rule sets updated daily from threat intelligence feeds.
- Monitor dark web forums and marketplaces using threat intelligence platforms (e.g., Recorded Future, Darktrace) to identify exposed organizational data, with daily reports generated, analyzed by a dedicated threat analyst, and cross-referenced with internal logs.

5— Conduct periodic log reviews (e.g., weekly) to establish baselines for normal activity (e.g., average login times, data transfer rates) and detect subtle anomalies, with findings documented in a centralized log management system.

- Implement user behavior analytics (UBA) tools (e.g., Exabeam) to flag deviations such as late-night access by non-IT staff, enhancing early detection capabilities.

• **Incident Classification:**

Implement a severity scale: Low (minor system slowdown with no data impact), Medium (limited data exposure affecting $\geq 1\%$ of records), High (critical data breach or service disruption impacting $\geq 1\%$ of operations).

- Example: A High severity incident occurs if 10,000 customer records are encrypted and a ransom is demanded, triggering immediate escalation to the CISO and legal team.

- Assign a classification team comprising a security analyst, network engineer, and compliance officer to evaluate impact on operations (e.g., downtime hours), finances (e.g., estimated loss in USD), and reputation (e.g., media coverage potential), with a decision matrix to standardize outcomes.

- Document classification rationale in a detailed report, including supporting evidence (e.g., log excerpts, IOCs) for audit purposes.

• **Compliance Step:**

- Log the precise detection time (e.g., 09:15 AM, May 09, 2025) with GPS stamped evidence, photographic documentation of affected systems, and digital signatures from the detecting analyst for GDPR, DORA, and local law compliance.

- Appoint a dedicated compliance officer to track notification deadlines using a digital dashboard (e.g., Microsoft Project) with automated reminders, ensuring adherence to 72-hour GDPR, 24-hour DORA, and local timelines.

- Conduct an initial compliance check to determine applicable regulations based on data type (e.g., personal data for GDPR, financial data for DORA), jurisdiction,

–

and incident scope, with a checklist reviewed by the legal department. – Preserve initial detection logs in a read-only format to meet forensic standards, with a backup copy stored offsite.

• **Initial Reporting:**

6– Notify the Incident Response Team Manager within 15 minutes via SMS, encrypted email, and a secure chat platform (e.g., Slack), using a standardized incident report template with fields for time, affected systems, initial observations, and severity.

- Log all incident details—date, time, affected systems, IP addresses, user accounts, and initial observations—in a tamper-proof database (e.g., ElasticSearch) with audit trails, digital signatures, and encryption to prevent tampering.
- Escalate to executive leadership (e.g., CISO, CEO) if the incident involves critical infrastructure (e.g., ERP systems), exceeds predefined financial thresholds (e.g., 500,000 Dollars potential loss), or attracts media attention, with a formal escalation memo.
- Distribute a preliminary briefing to all relevant teams (security, legal, communications) within 30 minutes, outlining next steps and resource needs.

2.3

Containment

• **Short-Term Containment:**

- Isolate affected systems by segmenting the network (e.g., VLAN 10 for compromised servers) to prevent lateral movement, using firewall rules configured in real-time by network engineers with input from threat intelligence feeds.
- Block malicious IP addresses and domains identified through platforms like Recorded Future, with immediate updates to perimeter defenses (e.g., Palo Alto Networks firewalls) and verification of blocks through packet analysis. – Disconnect external connections (e.g., VPNs, cloud services like AWS) if deemed

necessary to halt the attack, with a risk assessment to balance containment speed and operational impact, documented for later review.

- Notify affected users (e.g., via email or system alerts) to avoid further interaction with compromised systems, with a follow-up survey to gauge compliance.

• **Long-Term Containment:**

- Deploy honeypots on a separate subnet to lure attackers, gather intelligence on their tactics (e.g., command sequences, exfiltration methods), and monitor activity 24/7 using a dedicated honeypot management tool (e.g., Cowrie).

Use EDR (CrowdStrike Falcon) to automatically quarantine infected end points, prevent further execution of malicious code, and generate detailed quarantine reports for analysis, with manual overrides for complex cases.

7– Implement traffic filtering rules to block command-and-control (C2) communications, with regular updates based on IOCs from threat intelligence, and test filters in a sandbox environment to avoid false positives.

- Establish a containment monitoring team to oversee isolated systems, log all changes, and report to the Team Manager every 2 hours during the containment phase.

• **Evidence Preservation:**

- Create forensic images of affected systems using FTK Imager, with hash verification

(MD5, SHA-256) to ensure integrity, and store in a write-protected format on a dedicated forensic workstation.

- Use a secure evidence vault (e.g., HashiCorp Vault) with access restricted to authorized forensic personnel, logged entry/exit times, and biometric authentication to prevent unauthorized access.

–

- Maintain a detailed chain of custody with signed affidavits from all handlers, including timestamps, photographic evidence of the process, and a custody transfer log, reviewed by the legal department.
- Retain evidence for a minimum of 7 years to comply with potential legal requirements, with an annual audit to verify storage conditions and accessibility.
- Conduct a pre-preservation scan to identify volatile data (e.g., RAM contents) using tools like Volatility, ensuring no loss of critical evidence.

• **Compliance Step:**

- Document every containment action with video recordings (e.g., 1080p with audio), timestamps, and personnel signatures for GDPR and HIPAA (if applicable) audits, stored in an encrypted repository.
- Ensure all sensitive data remains encrypted using AES-256 standards through out the containment process, with a compliance officer verifying encryption status hourly.
- Conduct a preliminary compliance review to confirm adherence to notification timelines (e.g., 72-hour GDPR), with a written report submitted to the legal department within 2 hours of containment initiation.
- Prepare a compliance log detailing all actions, personnel involved, and tools used, to be included in the final incident report.

2.4

Eradication

• **Threat Removal:**

- 8– Run multi-engine antivirus scans using Malwarebytes and Kaspersky to detect and remove malware, with results cross-verified for accuracy and stored in a scan report for audit purposes.

- Perform sandbox analysis with Cuckoo Sandbox to dissect malware behavior, identify command structures, develop specific removal scripts, and simulate malware execution to understand its spread pattern.
- Manually review system files, registry entries, and network configurations to ensure no hidden payloads or backdoors remain, with changes logged in a detailed eradication journal.
- Deploy a cleanup script (e.g., PowerShell or Python) to remove residual malware components, tested in a staging environment before deployment.

• **Vulnerability Patching:**

- Apply patches via WSUS (Windows Server Update Services) after testing in a staging environment to avoid unintended disruptions, with a rollback plan in case of issues.
- Disable legacy protocols (e.g., SMBv1, Telnet) linked to known vulnerabilities like WannaCry, with documentation of changes and a verification scan post disablement.
- Conduct a post-patch vulnerability scan using Nessus to confirm resolution of

exploited weaknesses, with results reviewed by a security analyst and archived for compliance.

- Update firmware and software dependencies (e.g., Java, Apache) to prevent recurrence, with a schedule for ongoing updates maintained by the IT team.

• **Compliance Step:**

- Verify data integrity post-eradication with checksum comparisons (e.g., before and after hashes using MD5 and SHA-256) to ensure no corruption or loss, with results signed by a compliance officer.
- Engage legal counsel to conduct a compliance audit, reviewing all eradication steps against GDPR (data integrity), DORA (system resilience), and local laws, with a detailed audit report.
- Update incident logs with eradication details (e.g., tools used, time taken, personnel involved) for transparency and regulatory reporting, stored in an encrypted database.
- Notify affected stakeholders (e.g., IT staff, regulators) of eradication completion, with a compliance certificate issued if required by local law.

2.5

Recovery

• **System Restoration:**

- Restore systems from encrypted backups using a phased approach: test restoration on a sandbox environment to verify data integrity, validate functionality with a test suite, then deploy to production with a rollback option if issues arise.

- Verify system functionality with penetration testing (e.g., Metasploit) to identify residual vulnerabilities, conducted by a certified ethical hacker, with a report detailing findings.
- Reconfigure network settings (e.g., firewall rules, VPN access) and re-enable services incrementally, with monitoring for anomalies using SIEM during the process, and a 24-hour stabilization period.
- Train end-users on new system configurations post-restoration, with a helpdesk support team available for 48 hours to address issues.

• **Compliance Notifications:**

- Send GDPR notifications via encrypted email with a 72-hour deadline tracker, including a detailed breach description, mitigation steps, and a contact point, with delivery receipts archived.
- Issue HIPAA notifications within 60 days if health data is involved, using a standardized letter template (e.g., "Your data was breached on May 09, 2025; steps taken include encryption restoration..."), mailed via certified post.
- Submit DORA and local authority reports within 24 hours via secure online portals (e.g., with PDF uploads), with supporting documentation (e.g., evidence logs, eradication reports) and a follow-up call to confirm receipt.
- Maintain a notification log with recipient confirmations, response times, and any follow-up actions, reviewed quarterly for compliance audits.
- Provide affected individuals with access to a dedicated support line and website for breach-related inquiries, staffed for 30 days post-notification.

• **Interagency Coordination:**

- Coordinate with local cybersecurity authorities as per jurisdictional requirements, submitting a formal incident report with an executive summary,

technical details, and impact assessment, delivered via encrypted email or secure portal.

10– Engage HIPAA OCR and GDPR Data Protection Officers via secure channels (e.g., encrypted email with PGP, secure video calls) if applicable, with follow up calls to confirm receipt and discuss next steps.

- Follow PPD-41 guidelines for multi-agency response, establishing a joint task force if the incident involves national security implications (e.g., critical infrastructure), with regular status updates.
- Document all interagency communications (e.g., emails, call transcripts) for compliance and future reference, stored in a centralized repository with access controls.
- Conduct a post-coordination review with agencies to assess collaboration effectiveness and identify improvements.

• **Post-Recovery Monitoring:**

- Run continuous SIEM monitoring for 60 days, with alerts configured for unusual activity patterns (e.g., repeated login failures, data spikes), reviewed daily by the security team.
- Conduct quarterly vulnerability scans with Nessus and manual reviews by the security team to ensure no lingering threats, with a detailed scan report submitted to management.
- Implement a 30-day post-recovery audit to assess the effectiveness of the restoration process, including system performance metrics, user feedback, and compliance adherence, with findings presented in a 20-page report.
- Establish a rapid response team to address any post-recovery incidents, with a 24/7 on-call rotation schedule.

2.6

Lessons Learned

• Post-Incident Review:

- Hold a 3-day review workshop with stakeholders (IT, legal, management, external auditors) to analyze root causes, impact, and response effectiveness, with daily sessions lasting 6 hours each.

- Use a 10-page report template with sections for cause analysis (e.g., "Phishing email with malicious attachment exploited unpatched software"), impact assessment (e.g., 500 records exposed, 200,000 Dollars loss), and solution recommendations (e.g., enhanced email filtering, patch management), supported by charts and graphs.

11– Invite external auditors to provide an independent perspective on the response, with a focus on compliance gaps and operational improvements, and incorporate their feedback into the final report.

- Conduct a root cause analysis (RCA) using the 5-Whys technique or fishbone diagram, with results validated by a cross-functional team.

• Plan Updates:

- Revise the IRP with new threat intelligence (e.g., integrate AI-based anomaly detection using Darktrace) based on review findings, with updates tested in a sandbox environment.

- Update compliance policies annually with legal input, incorporating changes in regulations (e.g., new GDPR guidelines), industry standards (e.g., NIST updates), and internal incident data.

- Test updated plans in a simulated environment before full deployment, with a pilot run involving 10% of the organization's systems and a post-test evaluation.
- Establish a change management process to document all updates, with version control and approval from the CISO.

- **Training Improvements:**

- Launch a quarterly phishing simulation campaign with 100+ employees, tracking click rates, providing personalized feedback, and offering remedial training for those who fail, with results analyzed in a quarterly report.
- Document training attendance, test scores, and improvement areas in a CRM system (e.g., Salesforce) for compliance tracking, with a dashboard for real time monitoring.
- Offer advanced training sessions (e.g., incident simulation labs using virtual machines, forensic workshops) for high-risk roles (e.g., IT admins, security analysts), with a certification track.
- Conduct a post-training survey to gather employee input on training effectiveness, with adjustments made based on feedback.

3

Roles and Responsibilities

Each role is defined with exhaustive duties, escalation paths, collaboration requirements, training obligations, and practical examples for a general organization.

3.1

Incident Response Team Manager

- **Duties:** Oversees all phases of the IRP, approves budgets up to 500,000 Dollars for response efforts, and serves as the primary liaison with regulatory bodies, executive leadership, and external partners. Reviews daily incident reports, chairs response meetings, and ensures resource allocation (e.g., additional staff, tools).
- **Escalation:** Escalates to the Chief Information Security Officer (CISO) or CEO if the incident impacts critical systems (e.g., ERP, customer portals), exceeds 1M

Dollars in potential loss, or attracts media attention, with a formal escalation memo including financial and reputational risk assessments.

- **Collaboration:** Coordinates with the legal department to ensure compliance, the communications officer to manage stakeholder updates, the forensics team to oversee evidence handling, and the network team to align containment strategies, with weekly coordination meetings.
- **Training:** Leads quarterly briefing sessions (2 hours each) to align the team on objectives, ensures team readiness through bi-monthly drills simulating ransomware and DDoS attacks, and maintains personal certification in incident management (e.g., Certified Incident Manager).
- **Example:** During a ransomware incident, the Manager allocates 300,000 Dollars for tool upgrades, liaises with the GDPR DPO, and escalates to the CEO when media coverage begins.

3.2

Security Analyst

- **Duties:** Monitors SIEM and EDR alerts 24/7, writes detailed incident reports with technical analysis (e.g., IOCs, attack vectors), trains junior analysts on threat detection techniques, and maintains threat intelligence feeds (e.g., ThreatConnect).

Conducts daily security reviews and responds to alerts within 10 minutes.

- **Escalation:** Reports high-severity incidents to the Team Manager within 15 minutes, provides a preliminary analysis, and assists in classification with supporting evidence (e.g., log files).
- **Collaboration:** Works with network engineers to identify IOCs (e.g., malicious IPs), with forensics experts to validate findings (e.g., malware samples), and with

the legal team to document evidence, with joint review sessions every 4 hours during an incident.

13• Training: Maintains proficiency with threat intelligence platforms (e.g., Threat Connect, Recorded Future) through bi-monthly update sessions, completes annual cybersecurity courses (e.g., SANS), and mentors new hires with hands-on labs.

- **Example:** During a phishing attack, the Analyst detects a malicious email, traces its source to a known botnet, and trains the team on updated filtering rules.

3.3

Network Engineer

- **Duties:** Manages firewall rules and network segmentation during containment, restores network services post-recovery, documents all changes with timestamps and diagrams, and certifies network security with a post-recovery audit. Monitors network performance during incidents.
- **Escalation:** Notifies the Team Manager if containment fails (e.g., malware spreads despite isolation) or network restoration exceeds 24 hours, with a technical report outlining the issue.
- **Collaboration:** Coordinates with security analysts to implement IOC-based blocks (e.g., firewall updates), with the recovery team to test restored systems (e.g., load testing), and with the forensics team to preserve network logs, with daily sync-ups.
- **Training:** Certifies network security post-recovery with a CCNP certification, participates in annual network security workshops (e.g., Black Hat), and conducts internal training on segmentation techniques.
- **Example:** During a DDoS attack, the Engineer reroutes traffic through Cloudflare, blocks 50 malicious IPs, and restores services after a 6-hour outage.

3.4

Digital Forensics Expert

- **Duties:** Leads evidence collection using NIST-compliant methods (e.g., bit-by-bit imaging), testifies in legal proceedings if required, maintains a forensic lab with ISO 17025 accreditation, and analyzes malware samples with detailed reports. Oversees evidence chain integrity.
- **Escalation:** Reports evidence tampering or integrity issues (e.g., hash mismatch) to the Team Manager and legal department immediately, with a forensic incident report.
- **Collaboration:** Works with security analysts to analyze malware (e.g., sandbox results), with the legal team to prepare court-ready documentation (e.g., affidavits), and with the recovery team to verify data integrity, with bi-weekly forensic reviews.
- 14• **Training:** Conducts monthly forensic technique updates (e.g., new imaging tools), certifies lab staff annually with CFE certification, and attends forensic conferences (e.g., DFRWS).
- **Example:** During a ransomware case, the Expert creates a forensic image, traces the attack to a phishing email, and prepares evidence for a GDPR audit.

3.5

Communications Officer

- **Duties:** Drafts notifications for customers, employees, and regulators in multiple languages (e.g., English, Spanish), manages media inquiries with press releases, maintains a communication log, and updates stakeholders every 4 hours during an incident. Oversees social media monitoring.

- **Escalation:** Escalates to the Team Manager if media coverage escalates (e.g., national news) or stakeholder backlash intensifies (e.g., 1000 complaints), with a crisis management plan.
- **Collaboration:** Coordinates with the legal department for compliant messaging (e.g., GDPR wording), with the Team Manager for approval of public statements, and with the recovery team for customer support updates, with daily briefings. •
- **Training:** Participates in quarterly crisis communication training (e.g., PRSA workshops), maintains a media contact database with 50+ entries, and learns social media crisis management techniques.
- **Example:** During a data breach, the Officer issues a press release, handles 200 media calls, and sets up a customer helpline.

3.6

Legal Department

- **Duties:** Reviews compliance with GDPR, HIPAA (if applicable), DORA (if applicable), and local laws, files court orders for evidence preservation, conducts quarterly legal audits of the IRP, and advises on regulatory reporting. Drafts legal notices and contracts.
- **Escalation:** Escalates regulatory violations (e.g., missed GDPR deadline) or fines (e.g., €500,000) to the CISO and executive board, with a risk mitigation proposal.
- **Collaboration:** Works with the forensics team to ensure evidence admissibility (e.g., chain of custody), with the communications officer to draft legally sound notifications, and with the Team Manager to align on strategy, with weekly legal reviews.

15• **Training:** Attends annual data protection law seminars (e.g., IAPP), updates the compliance manual with new rulings, and trains staff on legal implications of incidents.

- **Example:** During a supply chain breach, the Legal team files for a court order, notifies the GDPR DPO, and audits the vendor contract.

4

Scenarios and Use Cases

This section provides highly detailed explanations of scenarios, their operational and compliance implications, and step-by-step use cases for a general organization, with extensive contextual analysis.

4.1

Scenario 1: Ransomware Attack

- **Description:** On May 09, 2025, at 09:00 AM, the LockBit ransomware variant encrypts 10,000 customer records stored in the organization's database, accessed via a phishing email opened by an employee. Attackers demand 5 Bitcoins (approximately 300,000 Dollars) for decryption, and a sample of the data is posted on a dark web forum (e.g., a .onion site), escalating the threat. The attack exploits an unpatched vulnerability in a Windows server, with initial entry through a compromised admin account. The organization faces potential financial loss, reputational damage, and regulatory scrutiny.

- **Use Case:**

- **Detection:** SIEM identifies unusual encryption activity (e.g., 500MB of data encrypted in 10 minutes) and login spikes from an unfamiliar IP, triggering an

alert to the SOC. Analysts manually review logs, trace the attack to the phishing email, and document findings in a 5-page report.

- **Containment:** Network engineers isolate the affected database server to VLAN 10, blocking malicious IPs (e.g., 192.168.1.100) using Palo Alto fire walls, and disconnect external cloud syncs (e.g., Google Drive). A honeypot is deployed to distract attackers, monitored for 48 hours.
 - **Eradication:** Security analysts run Malwarebytes to remove LockBit, patch the server with WSUS (e.g., MS21-1234), disable SMBv1, and manually clean registry entries. A sandbox analysis confirms no residual threats, with results logged.
 - **Recovery:** Systems are restored from a 48-hour-old backup, validated with MD5 checksums, tested with Metasploit for vulnerabilities, and monitored for 60 days. Users are retrained on phishing awareness, and a helpdesk supports 200 queries.
- 16– **Notification:** The legal department notifies the GDPR DPO within 72 hours with a 10-page report (breach details, mitigation), local authorities within 24 hours via a secure portal, and customers with a letter outlining compensation options (e.g., credit monitoring).
- **Compliance Impact:** GDPR requires a 72-hour notification with a risk assessment (e.g., 70% likelihood of harm), local laws may impose fines up to 1M Dollars, and reputational damage could lead to a 10% customer churn rate. The organization must demonstrate due diligence and data protection measures.
 - **Additional Considerations:** The organization assesses cyber insurance coverage (e.g., 500,000 Dollars policy), considers negotiating with attackers (if policy allows),

and launches a PR campaign with social media updates and a CEO apology video to rebuild trust.

4.2

Scenario 2: Phishing Attack

- **Description:** On May 09, 2025, an employee in the finance department clicks a phishing link in an email disguised as a vendor invoice, exposing 500 customer records. The attacker gains temporary access to the CRM system, downloading sensitive data (e.g., names, credit card numbers) before being detected. The incident

is traced to a lack of employee training and weak email filters, with the attacker using a spear-phishing technique targeting high-value accounts.

- **Use Case:**

- **Detection:** EDR detects unauthorized access attempts (e.g., 10 login failures from a new device), and analysts review email logs, identifying the phishing link's URL (e.g., <http://fakevendor.com>). A 3-page detection report is compiled.
- **Containment:** Credentials are revoked using Active Directory, the affected workstation is quarantined with CrowdStrike, and network traffic from the employee's IP is blocked. A forensic image is created for evidence.
- **Eradication:** Passwords are reset with a 16-character policy, email filters are updated with AI-based threat detection (e.g., Darktrace), and the employee undergoes mandatory retraining with a 2-hour session.

- **Recovery:** Data integrity is verified with checksums, the CRM system is restored with enhanced access controls (e.g., role-based access), and a system audit confirms no further exposure.
- **Notification:** The GDPR DPO is informed within 72 hours with a breach summary, internal audits are conducted, and a memo is sent to all staff on phishing risks.

17• Compliance Impact: GDPR mandates notification and a review of data processing activities (e.g., CRM access logs), while DORA (if applicable) requires a 24-hour report if financial data is involved, with potential fines of €100,000. Internal policy violations may trigger HR actions.

- **Additional Considerations:** The organization reviews email security (e.g., DMARC setup), updates its training program with simulated phishing tests, and considers legal action against the attacker if identifiable.

4.3

Scenario 3: Insider Threat

- **Description:** On May 09, 2025, a disgruntled employee in the IT department leaks 1,000 customer records to a competitor via a personal USB drive, detected after a routine DLP scan. The motive is retaliation for a denied promotion, with the employee using admin privileges to bypass security controls. The breach exposes names, addresses, and purchase histories, risking competitive disadvantage.
- **Use Case:**
 - **Detection:** DLP flags the data transfer (e.g., 500MB to an unapproved device), and analysts review access logs, identifying the employee's account activity over 3 days.

- **Containment:** The employee's access is suspended via Active Directory, the USB drive is confiscated by IT security, and a network audit blocks similar devices.
- **Eradication:** Employment is terminated with a documented exit process, access logs are audited for 30 days to ensure no other leaks, and security policies are updated.
- **Recovery:** Affected customers are notified with a letter, data access policies are tightened (e.g., two-factor authentication), and a risk assessment is conducted.
- **Notification:** Local authorities and the GDPR DPO are informed, with a police report filed and legal action initiated against the insider.
- **Compliance Impact:** GDPR requires breach reporting within 72 hours, and local laws may involve criminal charges (e.g., up to 5 years imprisonment); the organization must prove monitoring efforts.
- **Additional Considerations:** HR policies are reviewed for grievance handling, a whistleblower program is implemented, and employee monitoring is enhanced with consent forms.

184.4

Scenario 4: Distributed Denial of Service (DDoS) Attack

- **Description:** On May 09, 2025, a DDoS attack floods the organization's website with 500 Gbps of traffic, causing a 6-hour downtime during a peak sales period (e.g., Black Friday). The attack is launched by a competitor using a botnet of 10,000 compromised devices, aiming to disrupt e-commerce operations and cause financial loss estimated at 1M Dollars.

- **Use Case:**

- **Detection:** Wireshark identifies traffic spikes (e.g., 400% above baseline), and SIEM generates an alert, with analysts tracing the attack to multiple IP ranges.
- **Containment:** Traffic is rerouted through a Content Delivery Network (CDN) like Cloudflare, with rate-limiting applied (e.g., 100 requests/second), and a secondary server is activated.
- **Eradication:** Malicious IPs (e.g., 50 unique addresses) are blocked, and the botnet source is traced with ISP cooperation, with a cease-and-desist letter sent.
- **Recovery:** Website services are restored, performance is tested with load balancers (e.g., 2000 concurrent users), and customers receive a discount code as compensation.
- **Notification:** Local authorities are informed if required, and customers receive a service update via email and social media.
- **Compliance Impact:** DORA (if applicable) requires a 24-hour report, and downtime may trigger service level agreement (SLA) penalties (e.g., 10% of contract value), with potential customer lawsuits.
- **Additional Considerations:** The organization enhances DDoS protection with a Web Application Firewall (WAF), reviews vendor SLAs with Cloudflare, and conducts a post-incident capacity analysis.

4.5

Scenario 5: Supply Chain Attack

- **Description:** On May 09, 2025, a third-party vendor's software update (e.g., CRM plugin) introduces malware, compromising 5,000 customer records. The vulnerability is a backdoor in the vendor's code, detected after a routine security scan, with the attack exploiting a misconfigured API. The breach exposes payment details, risking fraud and regulatory fines.

- **Use Case:**

19– **Detection:** SIEM detects unusual activity from the vendor's software (e.g., 2GB data exfiltration), and a Nessus scan reveals the backdoor, with a 5-page detection report.

– **Containment:** Vendor integrations are isolated (e.g., API calls blocked), affected systems are taken offline, and a quarantine zone is created for analysis. –

Eradication: The vendor's software is removed, systems are patched, and the vendor is audited for negligence, with a forensic report submitted.

– **Recovery:** Data is restored from backups, third-party access is re-evaluated (e.g., new API keys), and a security review is conducted.

– **Notification:** The GDPR DPO is notified within 72 hours with a breach summary, and the vendor is held accountable with a demand letter.

- **Compliance Impact:** GDPR requires notification and a review of third-party contracts, with potential fines of €250,000 for the vendor and 100,000 Dollars for the organization.

- **Additional Considerations:** The organization terminates the vendor contract, seeks legal recourse (e.g., breach of contract claim), and updates its supply chain security policy.

Common Cyber Incidents and Handling Methods:

Cyber incidents are divided into five main categories:

1. Email
2. Network
3. Social Engineering
4. Web Services
5. Data Leakage

1. Email:

- **Email Classification (Malicious):**

- Phishing Email
- Spam Email ◦
- Campaigns ◦
- Targeting

a. Phishing Email:

Impersonating a trustworthy entity through email messages to obtain sensitive information, such as usernames, passwords, or credit card details, for malicious purposes.

- **Scenario 1:**

- If a user interacts with a phishing email by clicking a link or opening an attachment:
 - **Actions:**
 - Isolate the system from the network.
 - Change the user's password and any other saved passwords.
 - Inspect the email's links and attachments in an isolated lab. Extract Indicators of Compromise (IOCs).

- ▢ Analyze suspicious connections through the Centralized Log Center (SEIM).
- ▢ Ensure no similar phishing emails are present for other users. Send security alerts if other recipients exist.
- ▢ Block the email's source and malicious links through security systems.
- ▢ Scan the system with anti-malware software.
- ▢ Restore the system after ensuring it's free of malicious activity.

- **Scenario 2:**

- If a user receives a phishing email but does not interact with it.
 - ▢ **Actions:**
 - ▢ Inspect the email's links and attachments. Extract IOCs.
 - ▢ Verify that the user did not interact with the email, via the SEIM system, or the email gateway.
 - ▢ Ensure no similar phishing emails are present for other users. Send security alerts if other recipients exist.
 - ▢ Block the email's source and malicious links through security systems.

- **Scenario 3:**

- If a user reports a suspicious email from an unknown source:
 - ▢ **Actions:**
 - ▢ Analyze the email's source using Email Header analysis to verify the sender.
 - ▢ Analyze links and attachments in an isolated lab.

b. Spam Email:

Using electronic messaging systems to send unsolicited messages.

- **Actions:**

- Block the email's source through the email application or security software.

c. Campaigns:

Coordinated attacks targeting multiple users to steal information.

- **Actions:**

- Identify users who received the email and alert them not to interact with it.
- Inspect the email's links and attachments. Extract IOCs.
- Analyze suspicious connections through SEIM.
- Block the email's source and malicious links.

d. Targeting:

Targeting a specific individual or group with malicious emails.

- **Scenario 1:**

- If a user receives a targeted email but does not interact with it.
 - **Actions:**
 - Inspect the email's links and attachments. Extract IOCs.
 - Verify that the user did not interact with the email, via the SEIM system, or the email gateway.
 - Ensure no similar emails are present for other users. Send security alerts if other recipients exist.
 - Block the email's source and malicious links.

- **Scenario 2:**

- If a user interacts with a targeted email by clicking a link or opening an attachment:
 - **Actions:**
 - Isolate the user's system from the network.
 - Change the user's password.

- Inspect the email's links and attachments. Extract IOCs.
- Analyze suspicious connections through SEIM.
- Ensure other employees do not receive the email. Send security alerts if other recipients exist.
- Block the email's source and malicious links.
- Re-image the system if malware infection is confirmed.

2. Network:

- Alerts from security software (AV, EDR, etc.).
- **Attack Types:**
 - Callback/C&C
 - Worms

Ransomware

- Brute Force Attack

Miners ◦ Ads/PUP

a. Callback/C&C:

Malware connecting to an attacker's server to receive commands.

- **Preparation:**
 - Identify communication contacts (network team, security team, developers).
 - Map the internal network.
 - Update security software.
- **Detection and Analysis:**
 - Analyze incoming and outgoing connections through SEIM.
- **Containment, Eradication, and Recovery:**
 - Disconnect the system from the network (EDR or manually).
 - Block suspicious IP addresses.
 - Reset passwords.
 - Acquire a copy of the system and RAM.
 - Extract IOCs through

various security tools. ○ Re-image the system or restore from backup. ○ Activate the incident recovery plan. ○ Lessons learned.

Monitor the network for suspicious activity.

b. Worms:

Self-replicating programs that spread across networks.

- **Preparation:**
 - Identify communication contacts. ◦ Map the internal network.
 - Update security software.
- **Detection and Analysis:**
 - Analyze connections through SEIM.
 - Identify the worm type and spread.
- **Containment, Eradication, and Recovery:**
 - Isolate the infected network zone.
 - Disconnect the system from the network. ◦ Isolate the infected network zone from the internal network. ◦ Stop infected processes. ◦ Block suspicious IP addresses. ◦ Acquire a copy of the system and RAM. ◦ Reset passwords.
 - Seek removal methods from vendor support or security websites. ◦ Extract IOCs. ◦ Re-image the system or restore from backup. ◦ Return the isolated network zone to the live environment. ◦ Allow access to the internet for the isolated network. ◦ Lessons learned.
 - Monitor the network for suspicious activity.

c. Ransomware:

Malware that encrypts data and demands a ransom.

- **Preparation:**
 - Identify communication contacts. ◦ Map the internal network.
 - Update security software.
- **Detection and Analysis:**
 - Analyze connections through SEIM.

-
- Identify the ransomware type and spread.
- **Containment, Eradication, and Recovery:**
 - Isolate the infected network zone.
 - Disconnect the system from the network.
 - Isolate the infected network zone from the internal network.
 - Block suspicious IP addresses.
 - Stop infected processes.
 - Reset passwords.
 - Acquire a copy of the system and RAM.
 - Extract IOCs.
 - Seek removal methods from vendor support or security websites.
 - Restore from backup.
 - Search for decryption tools.
 - Return the isolated network zone to the live environment.
 - Allow access to the internet for the isolated network.
 - Lessons learned.
 - Monitor the network for suspicious activity.

d. Brute Force Attack:

Repeated attempts to guess passwords.

- **Actions:**
 - Block the attacker's IP address.
 - Investigate the compromised user account.
 - Set a limit on failed login attempts.

e. Miners:

Malware that uses system resources for cryptocurrency mining.

- **Actions:**
 - Send an alert to IT support to remove the malware.
 - Block the malicious website.
 - Contact the website owner.

f. Ads/PUP:

Unwanted programs that install themselves.

- **Actions:**

- Send an alert to IT support to scan the system.

3. Social Engineering:

Using social tactics to deceive users.

- **Scenario 1:**

- An attacker registers on social media claiming to belong to your organization:

- **Actions:**

- Contact social media support to report the fake account.

- **Scenario 2:**

- An attacker contacts an employee with a job offer and sends a malicious file:

- **Actions:**

- Extract IOCs from the file.
 - Alert all employees not to interact with the attacker.

- **Scenario 3:**

- An attacker contacts an employee with a job offer and sends a malicious file, and the employee opens it.

- **Actions:**

- The incident response depends on the malicious file type (Callback, Worm, Phishing, etc.).

4. Web Services:

Websites are considered external gateways through which attackers can inflict damage on the targeted entity. Therefore, they are among the most important gateways that must be protected.

a. Distributed Denial of Service (DDoS) Attack:

Sending a large number of requests from multiple sources at the same time in an attempt to disrupt the system and make its services unavailable.

-

- **Preparation:**

- Communicate with the web service provider to determine the available services for countering DDoS attacks and the procedures that must be followed when exposed to an attack.
- Create a whitelist of IP addresses and ports that should be filtered in the event of an attack.
- Determine all the technical infrastructure details of the network design, services, and server owners.
- Harden the network, systems, and servers that may be targeted by the attack.
- Determine the normal data flow volume in the network for detection purposes, as any sudden increase in volume may indicate a pending attack.
- Identify communication contacts, including the network and systems team, the web service provider, and the information security team.
- Prepare an incident response plan for services in case of exposure to an attack.

- **Detection and Analysis:**

- Identify the protocols, IP addresses, ports, and links used in the attack.

- **Containment, Eradication, and Recovery:**

Block the ports or IP addresses used in the attack through security systems.

- Filter incoming traffic to mitigate the impact of the denial of service attack through a whitelist of IP addresses or geographical filtering.

- Utilize services that help in detection, such as traffic redirection.

Communicate with the web service provider to counter the attack.

-

Restore all affected services to their previous state after ensuring no backdoors are present in the network.

- Lessons learned from the incident.

- Monitor the network for suspicious activity.

b. Website Defacement:

Unauthorized access to websites to alter the content of the page.

- **Preparation:**

- Prepare an updated backup copy of the website for regular use.
- Define approved procedures for redirecting visitors to the backup copy.
- Use software that detects any modifications in the content quickly.

- **Detection and Analysis:**

- Monitor the content of website pages to detect any modifications.
- Check databases for any malicious files.

- **Containment, Eradication, and Recovery:**

- Isolate the infected web server from the network. ◦ Block IP addresses associated with the attack. ◦ Acquire a copy of the system and RAM. ◦ Extract IOCs through security software. ◦ Start investigating how the attacker gained access to the server and fix the problem. ◦ Ensure the vulnerability used in the attack is not present on other sites. ◦ Review all associated services on the infected server and ensure they are not infected.
- Reset all passwords for accounts associated with the server. ◦ Activate the backup website server copy and restore services. ◦ Lessons learned from the incident.
- Monitor the network for suspicious activity.

5. Information Leakage:

Information leakage refers to the transfer of data from an organization to an external entity that is not authorized to view it.

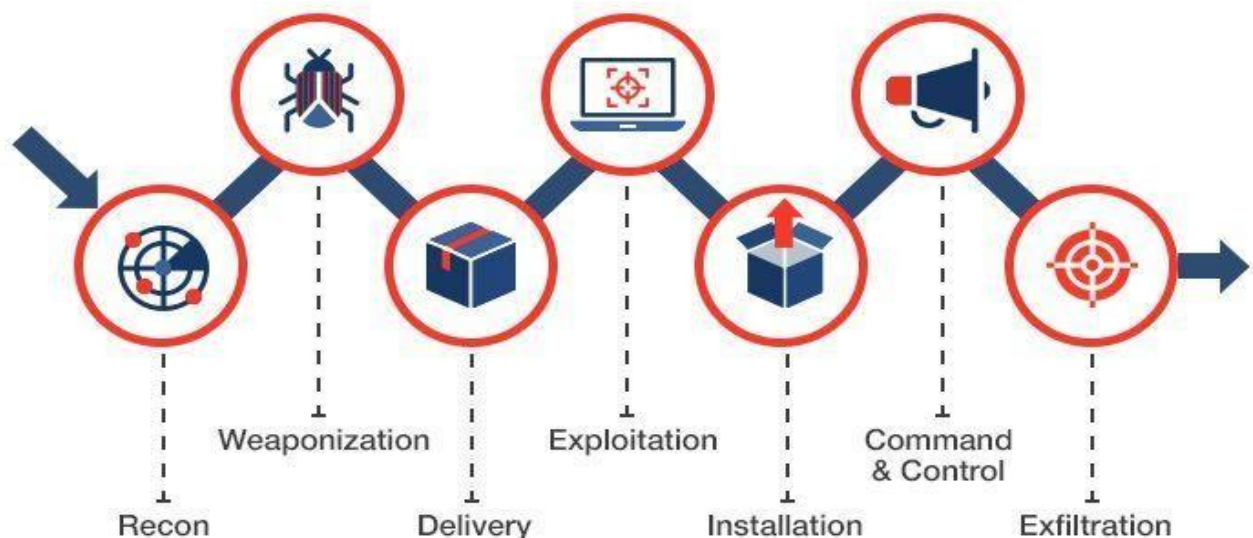
- **Preparation:**

-
- Classify data within the organization. ○ Prepare a response plan for leaked data. ○ Subscribe to threat intelligence services to identify information leakage to the organization.
- Implement security software to prevent information leakage.
- **Detection and Analysis:**
 - Determine the cause of the leak, whether it occurred from a third party or internally.
 - Search through databases or search engines for any external access to leaked data. ○ Use Data Loss Prevention (DLP) tools to help discover the cause of the leak.
- **Containment, Eradication, and Recovery:**
 - Suspend the employee's account after confirming that the leak occurred through it.
 - Isolate the device for digital forensic analysis.
 - Reset passwords for accounts that appeared in the leak. ○ Immediately contact the website where the data was exposed to delete the data. ○ Analyze the suspected data and take the necessary actions to make it useless.

Things to Avoid During Cyber Incident Response:

- **Do not shut down infected systems immediately:** It is preferable to isolate them from the network after the initial analysis of the incident.
- **Do not tamper with a full system copy:** When taking a full system copy, do not tamper with it. Additional copies should be taken for analysis.
- **Verify the absence of encryption on the hard drive:** After taking a copy of the RAM, if encryption is present on the hard drive level, a system copy should be made before shutting it down.
- **Use system administrator accounts:** For incident response.
- **Run incident response-specific software:** On infected systems.
- **Do not restore a backup copy of the infected system immediately after the recovery process:** The backup copy should be inspected and verified for the absence of any malicious software.

Cyber Kill Chain:



Attackers always follow a series of stages to reach their target. It is your responsibility to monitor the incident and determine the importance of the current stage to stop it and know how the previous stages were completed to create a defensive plan in the future.

Chain Steps:

2. Reconnaissance:

- Active or passive operations aimed at gathering as much information as possible about the targeted organization.

3. Weaponization:

- Preparing the appropriate vulnerabilities and tools for targeting.

4. Delivery:

- Determining the delivery method of the malicious software through one of the following methods:
 - Email
 - Internet-connected systems □ Portable USB storage drives

5. Exploitation:

- Exploiting a vulnerability in the operating system or services to run the malicious software and carry out espionage.

6. Installation:

- Installing the malicious software on the system.

6. Command & Control:

- Opening a channel to remotely control the system.

7. Objectives:

- After gaining full access, the attacker seeks to achieve their goal, whether it is data theft, infrastructure destruction, or file encryption.

Classification of Security Vulnerabilities:

Security vulnerabilities are discovered daily in operating systems, web applications, and software, and can be obtained from responsible or specialized external entities (NCANCS, Threat Intelligence, Vendors) or from anyone interested in discovering them. Studies conducted in 2020 indicated that the appearance of a vulnerability and the availability of its update are estimated at approximately 9 days, and the time

between the issuance of the update and the exploitation of the vulnerability by the attacker sometimes reaches only two hours (reports such as the FireEye report). The handling of the incident resulting from vulnerabilities depends on the sensitivity of the system in which the vulnerability was discovered and the extent of its risk, and the classification is based on four categories (low, medium, high, critical).

CYBERSECURITY RISK LEVELS	
CVE SCORE V3.1	
Severity	Base Score
No Risk	0
Low Risk	0.1–3.9
Medium Risk	4.0–6.9
High Risk	7.0–8.9
Critical Risk	9.0–10.0

a.

Critical:

- If the service is external, access to it from the outside should be immediately blocked until the problem is resolved or the system is updated.
- If blocking the service is not possible, work should be done immediately to mitigate the risk by blocking commands or access permissions (such as blocking some of the exploited ports or the commands used in the vulnerability).
- If the service is internal, work should be done immediately to update it to increase the speed of resolution within the organization.

b. High:

- If the service is internal/external, work should be done immediately to update it to increase the speed of resolution within the organization.

c. Medium:

- If the service is internal/external, work should be done immediately to update it to increase the speed of resolution within the organization.

d. Low:

- If the service is internal/external, work should be done immediately to update it to increase the speed of resolution within the organization.

Risk Mitigation:

There are sensitive services that cannot be stopped immediately due to business needs. Therefore, mitigation is used to expel the attacker and reduce the risk.

- **Steps:**
 - Update systems to close vulnerabilities. ◦ Block suspicious IP addresses discovered during analysis.
 - Restrict access to services and systems based on geographical location.
 - Change all passwords associated with the infected service.
 - Monitor the system or service through the Centralized Log Center (SEIM).

Determining Incident Response Priorities:

Time is a crucial element in incident response. The sooner an attack is detected, the less damage it will cause. The response team may face numerous security alerts simultaneously and may not have enough time to respond to all of them. Therefore, you must prioritize security alerts in this situation, arranging them from most important to least important.

Priority Determination:

Priorities are determined based on the following factors:

- **Location of the infected device on the network:** (Database Zone, Users Zone, Webserver zone, etc.)
- **Value of the data stored on the infected device:** (e.g., data stored on an employee's device vs. data in a research lab.)
- **Number and type of incidents that have occurred on the same device.**
- **Reliability of the Indicators of Compromise (IOCs) associated with the incident.**
- **The nature of the organization's business and the potential damage that incidents may cause:** (e.g., a research and development company considers data leakage and ransomware to be of high priority.)

Prominent Tools and Websites for Detection and Analysis:

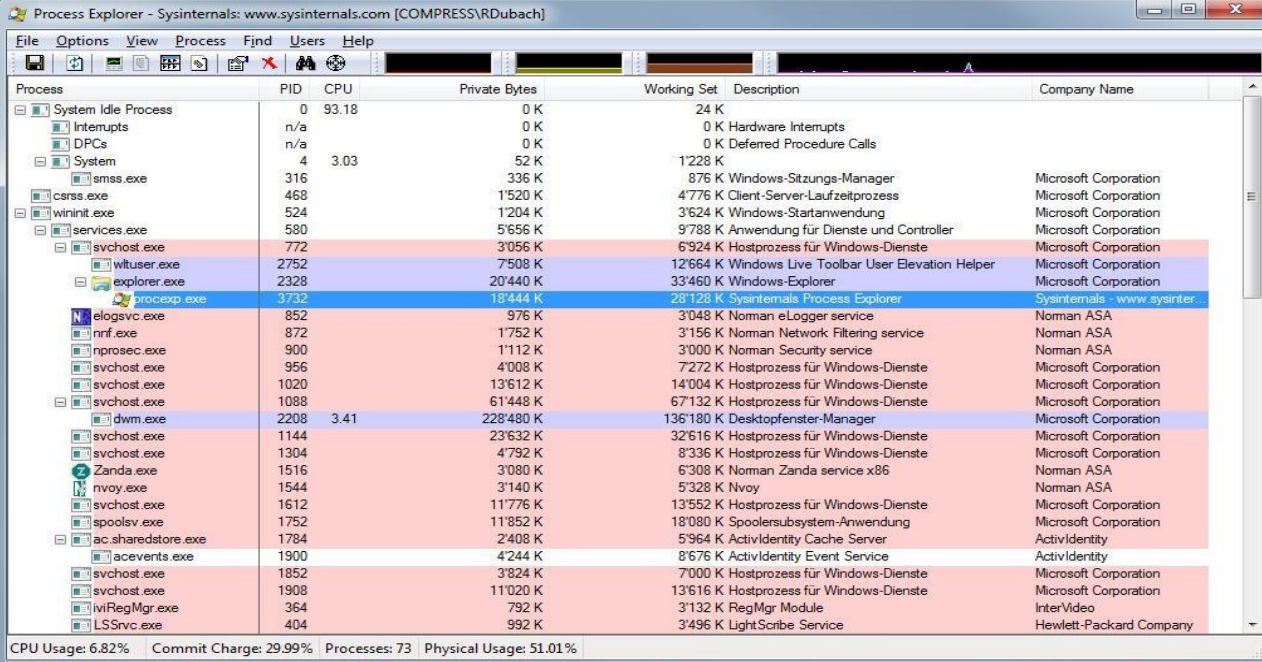
(Tools for Gathering Indicators of Compromise - IOCs)

Numerous tools assist in gathering Indicators of Compromise (IOCs), allowing for the detection of attacker activities. Here, we will mention some of them:

- Sysinternals Utilities
- AVZ
- YARA

a. Sysinternals Utilities:

A collection of tools for system administration and monitoring for Windows systems. It includes more than 60 tools, and these tools enable security analysts to collect IOCs and analyze compromised systems.



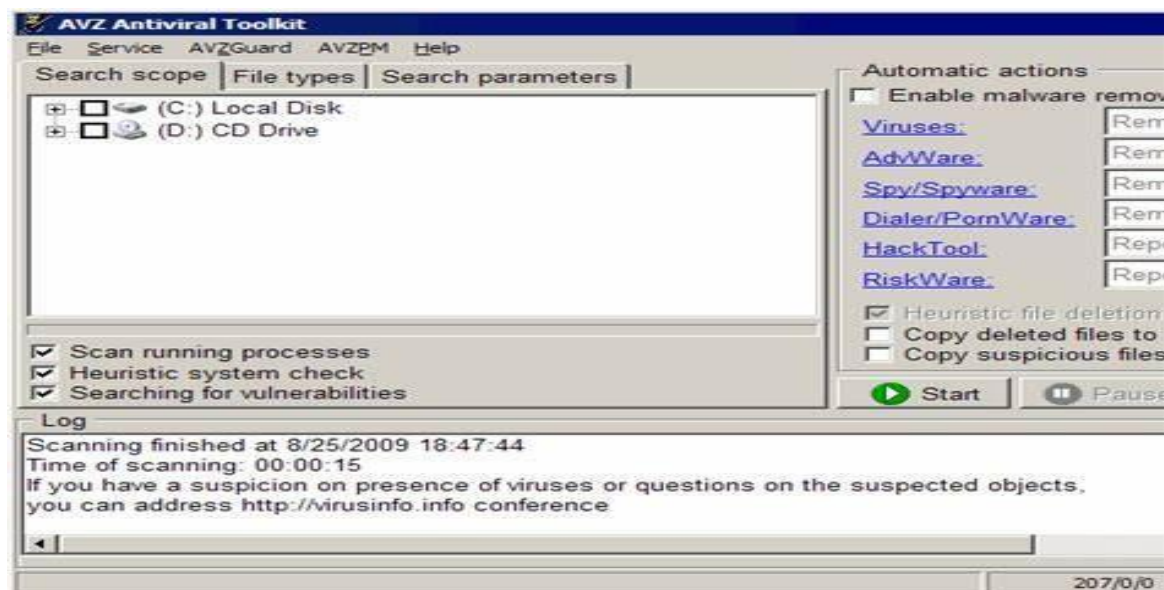
The screenshot shows the Process Explorer window from Sysinternals. The title bar reads 'Process Explorer - Sysinternals: www.sysinternals.com [COMPRESS\RDubach]'. The menu bar includes File, Options, View, Process, Find, Users, and Help. The main window displays a list of processes with columns for Process, PID, CPU, Private Bytes, Working Set, Description, and Company Name. The processes are organized into a tree view on the left, showing the hierarchy from System Idle Process down to various user applications. The status bar at the bottom indicates CPU Usage: 6.82%, Commit Charge: 29.99%, Processes: 73, and Physical Usage: 51.01%.

Process	PID	CPU	Private Bytes	Working Set	Description	Company Name
System Idle Process	0	93.18	0 K	24 K		
Interrupts	n/a		0 K		0 K Hardware Interrupts	
DPCs	n/a		0 K		0 K Deferred Procedure Calls	
System	4	3.03	52 K	1'228 K		
smss.exe	316		336 K		876 K Windows-Sitzungs-Manager	Microsoft Corporation
csrss.exe	468		1'520 K		4'776 K Client-Server-Laufzeitprozess	Microsoft Corporation
wininit.exe	524		1'204 K		3'624 K Windows-Startanwendung	Microsoft Corporation
services.exe	580		5'656 K		9'788 K Anwendung für Dienste und Controller	Microsoft Corporation
svchost.exe	772		3'056 K		6'924 K Hostprozess für Windows-Dienste	Microsoft Corporation
wituser.exe	2'752		7'508 K		12'664 K Windows Live Toolbar User Elevation Helper	Microsoft Corporation
explorer.exe	2'328		20'440 K		33'460 K Windows-Explorer	Microsoft Corporation
processp.exe	3'732		18'444 K		28'128 K Sysinternals Process Explorer	Sysinternals - www.sysinter...
elogsvc.exe	852		976 K		3'048 K Noman eLogger service	Noman ASA
nrf.exe	872		1'752 K		3'156 K Noman Network Filtering service	Noman ASA
nprosec.exe	900		1'112 K		3'000 K Noman Security service	Noman ASA
svchost.exe	956		4'008 K		7'272 K Hostprozess für Windows-Dienste	Microsoft Corporation
svchost.exe	1'020		13'612 K		14'004 K Hostprozess für Windows-Dienste	Microsoft Corporation
svchost.exe	1'088		61'448 K		67'132 K Hostprozess für Windows-Dienste	Microsoft Corporation
dwm.exe	2'208	3.41	228'480 K		136'180 K Desktopfenster-Manager	Microsoft Corporation
svchost.exe	1'144		23'632 K		32'616 K Hostprozess für Windows-Dienste	Microsoft Corporation
svchost.exe	1'304		4'792 K		8'336 K Hostprozess für Windows-Dienste	Microsoft Corporation
Zanda.exe	1'516		3'080 K		6'308 K Noman Zanda service x86	Noman ASA
nvoy.exe	1'544		3'140 K		5'328 K Nvoy	Noman ASA
svchost.exe	1'612		11'776 K		13'552 K Hostprozess für Windows-Dienste	Microsoft Corporation
spoolsv.exe	1'752		11'852 K		18'080 K Spoolersubsystem-Anwendung	Microsoft Corporation
ac.sharedstore.exe	1'784		2'408 K		5'964 K ActivIdentity Cache Server	ActivIdentity
acevents.exe	1'900		4'244 K		8'676 K ActivIdentity Event Service	ActivIdentity
svchost.exe	1'852		3'824 K		7'000 K Hostprozess für Windows-Dienste	Microsoft Corporation
svchost.exe	1'908		11'020 K		13'616 K Hostprozess für Windows-Dienste	Microsoft Corporation
wiRegMgr.exe	364		792 K		3'132 K RegMgr Module	InterVideo
LSrv.exe	404		992 K		3'496 K LightScribe Service	Hewlett-Packard Company

- You can download them from:
<https://technet.microsoft.com/enus/sysinternals/default.aspx>

b. AVZ:

A tool that assists in analysis and recovery.



- You can download it from: <http://www.z-oleg.com/secur/avz/download.php> c.

YARA:

A tool designed to assist malware analysts in identifying and classifying viruses and malicious software. It operates on multiple operating environments and can be used through the command line or Python scripts, and it is used from OS X, Linux, and Windows systems.

The image below represents a YARA Rule. Note that if one of the three conditions in any file is matched, that file must be considered a threat source.



- You can download it from: <http://virustotal.github.io/yara>

Tools for Creating Backups and Memory Dumps:

In this section, we will explain and use several tools to create backups of compromised systems and memory dumps.

- GRR Rapid Response
- Forensic Toolkit
- DumpIt
- Kape

a. GRR Rapid Response:

An incident response tool that helps security analysts create backups of compromised systems and analyze data extracted from those backups.

- **Key Features:**
 - Remote memory and Windows registry analysis.
 - Remote hard drive analysis.



- **Download:** <https://github.com/google/grr>

b. Forensic Toolkit (FTK):

A multi-purpose tool for digital forensics, including FTK Imager, which allows you to take a copy of the hard drive and memory.



- **Download:** <http://accessdata.com/solutions/digital-forensics/forensic-toolkit-ftk> c.

Dumplt:

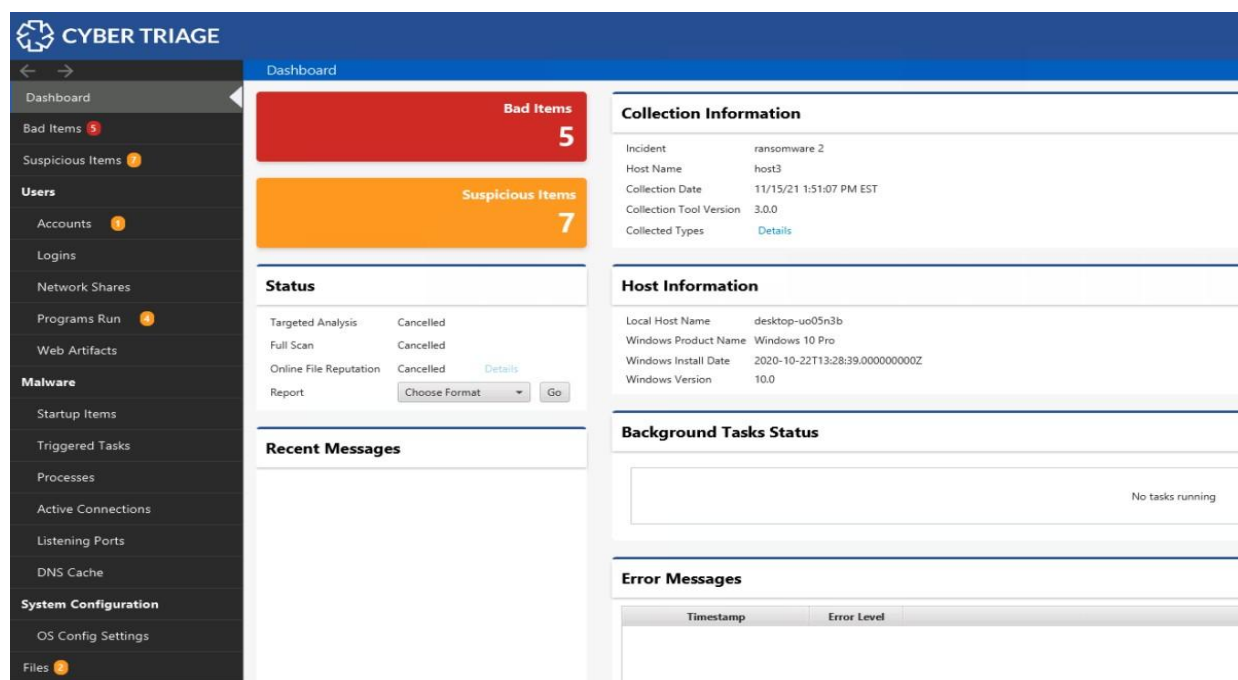
A digital forensics tool used to take a memory dump, known for its ease of use.



- **Download:** <https://github.com/thimbleweed/All-USB/tree/master/utilities/Dumplt> d.

Kape:

A digital forensics tool that collects and analyzes specific high-value "Artifacts" from compromised devices. It differs from other tools in that it extracts the artifacts needed for analysis rather than taking a full system copy, providing efficiency and speed.



- **Download:** <https://www.kroll.com/en/services/cyber-risk/incident-response/kapearthifact-support>

Tools and Websites for Analyzing Malicious Files and Potential Threats:

- Kaspersky Threat Intelligence Portal
- VirusTotal
- Anyrun
- Hybrid Analysis
- Cuckoo Sandbox

a. Kaspersky Threat Intelligence Portal:

A platform that gathers several tools for analysis, including:

- Threat Lookup
- Whois Tracking
- APT Reports
- Sandbox

a. Threat Lookup:

Contains all information about cyber threats collected by the Kaspersky Lab team, helping security professionals prevent attacks before they occur. **b. Whois**

Tracking:

Displays information about threat domains and IP addresses (e.g., domain creation date, hosting entity, IP address or domain). **c. APT Reports:**

Kaspersky reports help increase awareness and knowledge among professionals about advanced attacks in cyberspace. **d. Sandbox:**

A dedicated operating system for analyzing files and links to detect threats. It can be used to analyze suspicious files.



- **Website:** <https://opentip.kaspersky.com>

b. VirusTotal:

A platform dedicated to analyzing files and links to detect threats.



Analyze suspicious files and URLs to detect types of malware,
automatically share them with the security community

FILE
URL
SEARCH

Choose file

- Website: <https://www.virustotal.com/gui>

c. Anyrun:

An interactive platform dedicated to analyzing files and links to detect threats.

<https://app.any.run>

- Website: <https://app.any.run>

d. Hybrid Analysis:

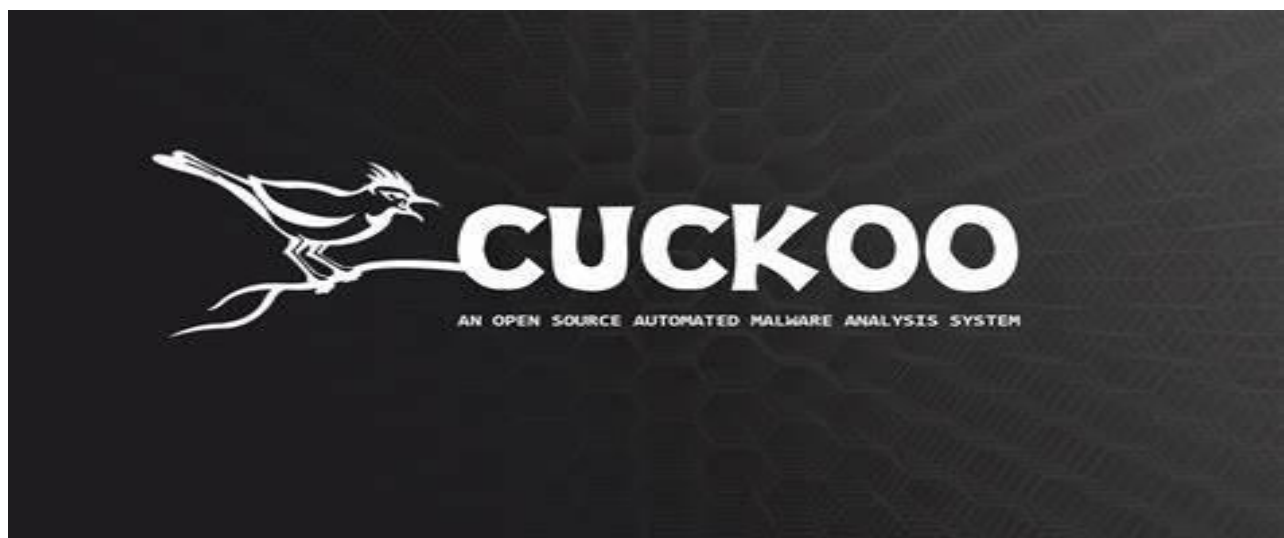
A platform dedicated to analyzing files and links to detect threats.



- **Website:** <https://www.hybrid-analysis.com>

e. Cuckoo Sandbox:

A dedicated operating system for analyzing files and suspicious links. It can be installed on a device connected to the organization's network to perform the necessary analysis without external access.



- **Official Website:** <https://cuckoosandbox.org>
- **Installation Guide:** <https://zone.com/2020/03/18/howto-use-and-setupcuckoovm-v2/>

Tools for Memory Analysis

- Volatility
- Rekall

A. Volatility

Volatility is a memory forensics tool used to extract digital artifacts from a volatile memory (RAM) dump, which is a snapshot of the random-access memory taken from an incident.



You can download it from: <http://www.volatilityfoundation.org>

B. Rekall

Rekall is also a memory forensics tool used to extract digital artifacts from a volatile memory (RAM) dump, which is a snapshot of the random-access memory taken from an incident. The tool also allows you to perform live analysis of RAM without taking a memory dump.

```
Terminal - backbox@backbox:~  
File Edit View Terminal Go Help  
backbox@backbox:~$ rekall -h  
usage: rekall [--autodetect_threshold AUTODETECT_THRESHOLD]  
             [--buffer_size BUFFER_SIZE] [--debug]  
             [--ipython_engine IPYTHON_ENGINE]  
             [--logging {debug,info,warning,critical,error}]  
             [--no_autodetect] [--output OUTPUT]  
             [--plugin PLUGIN [PLUGIN ...]] [--profile_path PROFILE_PATH]  
             [-f FILENAME] [-h] [-r RUN] [-v] [--dtb DTB] [-p PROFILE]  
             [--nocolors] [--pager PAGER] [--paging_limit PAGING_LIMIT]  
             [--renderer RENDERER] [--timezone TIMEZONE] [--ept EPT]  
             Plugin ...  
-----  
The Rekall Memory Forensic framework 1.0rc11.  
"We can remember it for you wholesale!"  
This program is free software; you can redistribute it and/or modify it under  
the terms of the GNU General Public License.
```

You can download it from: <http://www.rekall-forensic.com>

Tools for Hard Disk Analysis

- The Sleuth Kit (TSK)

The Sleuth Kit (TSK) is a collection of command-line tools that allow you to analyze hard disks and recover files. It does not have a graphical user interface (GUI), but the Autopsy tool acts as a GUI for TSK.



You can download The Sleuth Kit from: <http://www.sleuthkit.org/sleuthkit>

You can download Autopsy from: <http://www.sleuthkit.org/autopsy/>

Tools for Searching Strings

- Strings Utility

The Strings Utility is a tool used to search for strings. It is available in Windows, Unix, and Linux operating systems and helps to search within files for Unicode or ASCII characters. It can also search for strings in memory dumps extracted from compromised systems, such as (Windows registry, email bodies, addresses, links, etc.).

You can download it for Windows systems from:

<https://docs.microsoft.com/enus/sysinternals/downloads/strings>

Threat Intelligence Reports

There are trusted entities that work on collecting and monitoring information about suspicious activities in cyberspace and preparing reports on the detected attack patterns and behavior.

Examples of sources for threat intelligence reports:

- FireEye
- Verizon
- TrustWave
- Palo Alto Networks
- F-secure

Legal and Regulatory Requirements (with references to NIST and ISO)



- **Compliance with Laws and Regulations:**

- The organization must comply with all relevant local and international laws and regulations related to information security and data protection. This includes, but is not limited to:
 - Personal data protection laws (such as Egyptian Law No. 151 of 2020).
 - Cybercrime laws.
 - Regulatory requirements specific to various sectors (such as the financial or healthcare sectors).
- The incident response plan must be compatible with these requirements and define the procedures necessary to ensure compliance.
- **Guidance from the NIST Cybersecurity Framework (CSF):** The organization can benefit from the NIST Cybersecurity Framework as a guiding framework to identify and organize core cybersecurity functions, including incident response functions. This framework helps to identify risks, prioritize actions, and implement best practices.
- **Compliance with ISO 27001:** The organization can seek ISO 27001 certification, an international standard for Information Security Management Systems (ISMS). This standard helps to establish, implement, maintain, and improve an ISMS, including incident response procedures.

- **Incident Reporting:**

- In some cases, laws or regulations mandate that organizations report information security incidents to the competent authorities (such as the cybersecurity center). ○ The incident response plan must define the procedures for reporting incidents in a timely manner and identify the parties to be notified.
- **Incident Documentation:**
 - All incidents and the actions taken to respond to them must be documented accurately and completely.
 - The documentation should include information about the nature of the incident, the damage caused to the organization, the actions taken to contain, eradicate, and recover from the incident, and the evidence collected. ○ The documentation must be stored securely and retained for a period specified by laws and regulations.
 - **Guidance from ISO 27035:** The organization can benefit from ISO 27035, which provides detailed guidance on information security incident management, including documentation and investigation procedures.

Individual Roles in Incident Response (IR) during a Security Breach:



1. Incident Response Team (IRT):

-
- **Team Manager:**
 - Leads and coordinates the IR effort.
 - Makes critical decisions and communicates with senior management.
 - Ensures the effective execution of the IR plan.
- **Security Analyst:**
 - Analyzes the nature, scope, and impact of the attack. ○ Collects and analyzes digital evidence.
 - Identifies vulnerabilities and provides recommendations for improvement.
- **Network Engineer:**
 - Isolates compromised systems and implements containment measures. ○ Restores affected systems and returns them to operational status.
 - Monitors network traffic and identifies suspicious activity.
- **Digital Forensics Expert:**
 - Collects and preserves digital evidence in a legally sound manner. ○ Conducts detailed investigations to determine the source of the attack.
 - Provides detailed reports on investigation findings.
- **Communications Officer:**
 - Prepares and distributes internal and external communications. ○ Handles inquiries from media and regulatory bodies.
 - Maintains transparent communication throughout the response period.

2. Senior Management:

- **Strategic Decision-Making:**

-
- Sets response priorities and allocates resources.
- Approves containment and recovery plans.
- Makes decisions regarding incident reporting.
- **Stakeholder Communication:**
 - Informs customers, partners, and shareholders of the incident.
 - Addresses legal and regulatory implications.
 - Maintains company reputation and public trust.

3. IT Department:

- **Technical Support:**
 - Provides technical support to employees during the response period.
 - Implements containment and mitigation procedures.
 - Restores affected systems and applications.
- **System Monitoring:**
 - Monitors systems and networks for suspicious activity.
 - Applies security updates and patches.
 - Implements backup and recovery procedures.

4. Employees:

- **Incident Reporting:**
 - Reports any suspicious activity or security incident.
 - Follows security guidelines and procedures.
 - Avoids opening suspicious emails or links.
- **Collaboration with IRT:**
 - Provides information and assistance as required by the IRT.
 - Follows IRT instructions precisely.

-
- Maintains security awareness.

5. Legal Department:

- **Legal Compliance:**

- Ensures compliance with relevant laws and regulations.
- Provides legal advice regarding incident reporting.
- Handles any potential litigation.

- **Evidence Protection:**

- Ensures the preservation of digital evidence in a legally sound manner.
- Participates in digital forensics investigations.

Roles and Responsibilities within a Security Operations Center (SOC) during an Incident:



1. Tier 1 SOC Analyst:

- **Initial Monitoring:** Continuously monitors security alerts from various systems and tools.
- **Alert Triage:** Differentiates between false positives and genuine security incidents.
- **Preliminary Data Collection:** Gathers initial information regarding the detected incident.
- **Initial Classification:** Categorizes incidents based on severity and potential impact.
- **Escalation:** Escalates high-priority incidents to Tier 2 analysts.
- **Initial Reporting:** Generates preliminary incident reports and notifies the Incident Response Team of critical events.

2. Tier 2 SOC Analyst:

- **In-Depth Analysis:** Conducts thorough analysis of incidents escalated from Tier 1.

- **Scope and Impact Assessment:** Determines the scope and potential impact of the attack.
- **Digital Forensics:** Analyzes digital evidence to understand the attack vector.
- **Response Development:** Develops incident response plans and strategies.
- **Containment and Mitigation:** Implements containment and mitigation procedures.
- **Advanced Tool Utilization:** Utilizes advanced tools and techniques for incident investigation.
- **Detailed Reporting:** Generates comprehensive incident reports with recommendations.

3. SOC Engineer:

- **Security Tool Management:** Installs, configures, and maintains security tools used in the SOC.
- **Rule Development and Updates:** Develops and updates threat detection rules and signatures.
- **Automation:** Automates monitoring and response processes.
- **Infrastructure Optimization:** Optimizes the SOC's security infrastructure.
- **Solution Implementation:** Develops and implements new security solutions.
- **Tool health monitoring:** Ensures that all tools and programs are working correctly.

4. SOC Manager:

- **Team Management:** Manages and directs the SOC team.
- **Task Prioritization:** Prioritizes and assigns tasks.
- **Performance Evaluation:** Evaluates team performance and provides development opportunities.
- **Strategic Development:** Develops and implements the SOC's security strategy.

- **Risk Management:** Identifies and mitigates security risks.
- **Executive Communication:** Communicates the organization's security posture to senior management.
- **Coordination:** coordinates with other departments, and external parties when needed.

5. Threat Hunter:

- **Proactive Threat Detection:** Proactively searches for hidden threats within the network.
- **Advanced Analysis:** Uses advanced techniques to analyze data and detect suspicious activities.
- **Threat Intelligence:** Develops threat intelligence to identify potential threats.
- **IOC Development:** Develops Indicators of Compromise (IOCs) to identify threats.
- **Information sharing:** shares information with the SOC team.

6. Incident Responder:

- **Immediate Response:** Provides immediate response to security incidents.
- **Containment and Remediation:** Implements containment and remediation measures.
- **System Recovery:** Recovers affected systems.
- **Digital Forensics Investigation:** Conducts digital forensics investigations to determine the root cause of incidents.
- **Evidence Collection:** Collects and preserves digital evidence.
- **Investigation Reporting:** Generates incident investigation reports.